

DATA SECURITY POLICY

IT & Information Security Framework

Policy Version	1.0
Effective Date	January 1, 2025
Policy Owner	IT & HR Department
Review Cycle	Annually
Applies To	All Employees, Contractors, Vendors

1. Purpose and Scope

1.1 Purpose

This Data Security Policy establishes the framework and binding obligations that govern how all organizational data, information assets, technology resources, and digital systems are accessed, used, protected, and managed by every individual operating within or on behalf of the organization. In today's interconnected digital environment, the protection of sensitive information is not merely a technical challenge—it is a fundamental business imperative and a legal obligation.

The organization handles a vast range of sensitive data including personal employee records, client contracts and financial data, proprietary business strategies, intellectual property, and third-party vendor information. Any unauthorized access, misuse, loss, or disclosure of such information can result in severe financial penalties, irreparable reputational damage, regulatory sanctions, and legal liability. This policy aims to prevent such outcomes by establishing clear, enforceable rules for every person who interacts with organizational data and systems.

This policy is aligned with international standards and frameworks including ISO/IEC 27001 (Information Security Management), NIST Cybersecurity Framework, GDPR (General Data Protection Regulation), and other applicable national and regional data protection laws.

1.2 Scope

This policy applies universally to:

- All full-time and part-time employees across all departments, levels, and locations
- Contract workers, temporary staff, interns, and freelancers engaged by the organization
- Third-party vendors, partners, and service providers who have access to organizational systems or data
- Board members and executive leadership with access to sensitive organizational information
- Remote workers, hybrid workers, and employees on deputation or secondment

The policy covers all data — regardless of format (digital, physical, verbal) — that is created, received, stored, processed, or transmitted by or on behalf of the organization. It encompasses all devices (company-issued and personal), all networks, cloud platforms, third-party applications, and any technology tool used in connection with organizational work.

1.3 Policy Objectives

The primary objectives of this Data Security Policy are:

1. Confidentiality: Ensure that sensitive information is accessible only to those who are authorized and have a legitimate need to access it.

- 2. Integrity: Safeguard the accuracy and completeness of information and processing methods, preventing unauthorized modification or corruption of data.
- 3. Availability: Ensure that authorized users have reliable and timely access to information and associated assets when required.
- 4. Compliance: Meet all legal, regulatory, contractual, and organizational security requirements.
- 5. Accountability: Establish clear lines of responsibility for the protection and correct use of information assets.
- 6. Resilience: Enable the organization to detect, respond to, and recover from security incidents quickly and effectively.

KEY
PRINCIPLE

Every employee is a custodian of the organization's data. Security is everyone's responsibility — not just the IT department's.

2. Data Classification Framework

2.1 Why Data Classification Matters

Not all data carries the same level of sensitivity. Treating all information with the same controls would be both impractical and inefficient. The organization uses a tiered data classification system to help employees understand the sensitivity of information they handle and apply proportionate security measures accordingly.

Classification Level	Definition	Examples
Level 1 — Public	Information that is approved for public disclosure and poses no risk if shared externally.	Marketing brochures, published job postings, general website content, press releases
Level 2 — Internal Use Only	Information intended for use within the organization and not for external distribution. Limited risk if disclosed but may cause operational harm.	Internal memos, project plans, org charts, non-sensitive policies, meeting minutes
Level 3 — Confidential	Sensitive business information that could cause significant harm to the organization or individuals if disclosed without authorization.	Client contracts, employee salary data, financial reports, business strategies, vendor agreements
Level 4 — Restricted / Top Secret	Highly sensitive information whose unauthorized disclosure could cause severe harm, legal liability, or critical business damage.	Personal Identifiable Information (PII), trade secrets, M&A plans, source code, authentication credentials, medical/health records

2.2 Handling Requirements by Classification

Each classification level comes with specific handling requirements:

Level 3 — Confidential Data Handling

- Must be stored in access-controlled systems with role-based permissions
- Transmission must be encrypted (TLS 1.2 or higher for digital; sealed envelopes for physical)
- Must not be stored on personal devices or unauthorized cloud services
- Physical documents must be locked when unattended
- Disposal must be via secure shredding or certified data destruction services

Level 4 — Restricted Data Handling

- Access restricted to explicitly named individuals on a need-to-know basis
- Must be encrypted at rest and in transit using AES-256 or equivalent
- Access logs must be maintained and reviewed quarterly
- Cannot be transmitted via personal email, WhatsApp, or any non-corporate messaging platform
- Must be reported to IT immediately if lost, accessed without authorization, or suspected of compromise

REAL-
WORLD
EXAMPLE

An HR manager sends an employee's salary slip via their personal Gmail account to a colleague. Even though the intent was harmless, this violates the Confidential Data Handling policy — salary data is Level 3 and must only be transmitted through encrypted, company-approved channels. This could result in a formal warning.

3. Laptop and Device Usage Policy

3.1 Company-Issued Device Ownership and Purpose

Laptops, mobile phones, tablets, and other devices provided by the organization are company property and must be used primarily for legitimate business purposes. The organization invests significantly in providing employees with technology tools to enable productivity, collaboration, and communication. In return, employees are expected to use these resources responsibly, lawfully, and in a manner consistent with organizational values.

Company devices are not personal property. While limited personal use is tolerated (see Section 3.4), employees must understand that the organization retains the right to monitor, access, audit, and recover these devices at any time without prior notice.

3.2 Physical Security of Devices

Physical security of devices is as important as digital security. A lost or stolen laptop with unencrypted data can have the same catastrophic consequence as a cyberattack.

- Employees must never leave laptops unattended in public places such as cafes, co-working spaces, airports, or hotel lobbies.
- When traveling, laptops must be carried as hand luggage — never checked in as baggage.
- In the office, laptops must be locked using a cable lock when left unattended, even briefly.
- Laptops must always be locked (Windows + L / Cmd + Ctrl + Q on Mac) before stepping away, even for a few minutes.
- Screen privacy filters are mandatory for employees who frequently work in public or open-plan office areas and handle confidential data.
- Mobile devices must be kept in secure custody at all times and must be reported to IT within 2 hours of loss or theft.

3.3 Software Installation and System Configuration

All software installed on company devices must be approved by the IT department. Unauthorized software installations pose significant risks including malware infection, license violations, and system instability.

- Employees must NOT install any unapproved software, applications, or browser extensions without prior written IT approval.
- The following are explicitly prohibited: torrent clients, peer-to-peer (P2P) file sharing software, cracked/pirated software, gaming applications, cryptocurrency mining tools, and any software sourced from unofficial or unknown websites.
- Operating system and security patches must be installed promptly. Employees who dismiss system update notifications for more than 48 hours after notification will be contacted by IT.

- Modifying device settings, disabling firewalls or antivirus protection, or attempting to bypass IT controls is strictly prohibited.
- Only IT-approved VPN software must be used when accessing company systems remotely.

REAL-
WORLD
EXAMPLE

An employee at a software company installed a free screen recorder app from an unknown source for a client demonstration. The app contained spyware that transmitted keystrokes — including passwords — to a third party. The incident led to a client data breach, regulatory investigation, and termination of the employee. Always request IT approval before installing any new software.

3.4 Acceptable and Unacceptable Personal Use

Acceptable Personal Use	Unacceptable Use (Prohibited)
Occasional personal browsing during lunch breaks	Accessing adult or illegal content of any kind
Checking personal email briefly between tasks	Storing personal movies, music, or large media files
Using messaging apps for brief personal communication	Using the device for a personal business or side job
Online shopping during personal time	Downloading pirated content (music, movies, software)
Light social media use during breaks	Sharing the device with family members or friends
Accessing personal cloud storage briefly	Installing unauthorized VPNs or privacy tools

3.5 Device Return and End-of-Employment

All company devices must be returned in good working condition at the time of resignation, termination, or contract conclusion. Employees are responsible for:

- Returning devices within 24 hours of their last working day
- Not performing personal data wipes or factory resets — the IT department will handle all data sanitization
- Reporting any damages or malfunctions discovered at the time of return
- Understanding that failure to return devices may result in deductions from final settlement

4. Password Security Policy

4.1 Why Strong Passwords Matter

Passwords are the first and most fundamental line of defense against unauthorized access to organizational systems. Weak, reused, or improperly shared passwords account for over 80% of all data breaches globally. A single compromised password can give attackers access to email, financial systems, customer data, and internal communications.

4.2 Password Creation Standards

All passwords created for organizational systems must meet the following minimum requirements:

Minimum Password Requirements
Minimum length: 12 characters (16+ characters strongly recommended)
Must include at least one uppercase letter (A-Z)
Must include at least one lowercase letter (a-z)
Must include at least one number (0-9)
Must include at least one special character (!@#\$%^&*()_+~`{ }~;:'",./<>?)
Must NOT contain the employee's name, username, email address, or date of birth
Must NOT be a common word, phrase, or sequential pattern (e.g., 'Password1', 'Qwerty123', '12345678')
Must NOT be any previously used password (last 12 passwords are blocked)

4.3 Password Management Rules

- Passwords must be changed every 90 days for standard accounts and every 30 days for privileged/admin accounts.
- Passwords must NEVER be written on sticky notes, whiteboards, notebooks, or any visible surface.
- Passwords must NEVER be shared with anyone — not with a manager, not with IT support, not with colleagues. IT staff will NEVER ask for your password.
- Passwords must NEVER be reused across multiple systems (e.g., do not use the same password for your work email and your CRM login).
- The use of a company-approved Password Manager (e.g., LastPass Enterprise, 1Password for Business) is strongly encouraged and in some departments, mandatory.

4.4 Multi-Factor Authentication (MFA)

Multi-Factor Authentication adds a second layer of identity verification beyond the password. MFA is mandatory for all employees across the following systems:

- Corporate email (e.g., Google Workspace, Microsoft 365)
- VPN and remote access systems
- Financial and accounting platforms (e.g., ERP, accounting software)
- HR management systems containing employee records
- Any cloud-based SaaS platform storing Level 3 or Level 4 data
- Administrative or privileged access accounts of any kind

Acceptable MFA methods include authenticator apps (e.g., Google Authenticator, Microsoft Authenticator), hardware security keys (e.g., YubiKey), or organizational SSO solutions. SMS-based OTPs are permitted as a fallback but are not the preferred method due to SIM-swap vulnerabilities.

REAL- WORLD EXAMPLE

In 2023, a mid-sized financial services firm had an employee whose password was 'Company2023!' — which met basic requirements but was predictable. An attacker used credential stuffing to access the system after the same password was found in a breach of a different website. If MFA had been enabled, the breach would have been stopped despite the compromised password. This incident prompted the firm to mandate MFA across all systems.

4.5 Default and Service Account Passwords

- All default passwords on new devices, routers, printers, or software must be changed before the device/system is put into production use.
- Service account passwords must follow the same complexity requirements and must be stored in the IT password vault.
- Shared/team passwords (where unavoidable) must be managed through a team password vault and must be changed whenever a team member with access leaves the organization.

5. Data Privacy Policy

5.1 Governing Principles

Data privacy refers to the proper handling, processing, storage, and use of personal data in compliance with applicable privacy laws and in a manner that respects individuals' fundamental rights. The organization is committed to processing data lawfully, fairly, and transparently. Our data privacy practices are guided by the following principles:

7. Lawfulness, Fairness & Transparency: Data is processed only for lawful purposes and individuals are informed about how their data is used.
8. Purpose Limitation: Data collected for one purpose is not used for a different, incompatible purpose without consent.
9. Data Minimization: Only the minimum necessary data is collected and processed.
10. Accuracy: Personal data is kept accurate and up to date.
11. Storage Limitation: Data is retained only for as long as necessary, then securely deleted.
12. Integrity & Confidentiality: Data is protected against unauthorized access, loss, and destruction.
13. Accountability: The organization takes responsibility for compliance and can demonstrate it.

5.2 Types of Personal Data Handled

The organization regularly processes the following categories of personal data:

Data Category	Examples	Classification Level
Employee Personal Data	Name, address, phone, email, emergency contact	Level 3 — Confidential
Sensitive Personal Data	Health records, biometrics, religion, race	Level 4 — Restricted
Financial Data	Bank details, payroll, tax records	Level 4 — Restricted
Performance Data	Appraisals, KPIs, disciplinary records	Level 3 — Confidential
Client/Customer Data	Names, contact info, purchase history	Level 3-4 depending on nature
Vendor/Partner Data	Contact persons, contract terms, pricing	Level 3 — Confidential

5.3 Employee Rights Regarding Personal Data

All employees have the following rights with respect to their personal data held by the organization:

- Right of Access: Employees may request a copy of their personal data held by the organization.
- Right to Rectification: Employees may request correction of inaccurate or incomplete data.
- Right to Erasure: In certain circumstances, employees may request deletion of their data.
- Right to Restrict Processing: Employees may request limitation of how their data is used.
- Right to Data Portability: Employees may request their data in a portable format.
- Right to Object: Employees may object to certain processing activities including automated decision-making.

To exercise any of the above rights, employees must submit a formal Data Subject Access Request (DSAR) to the HR department or designated Data Protection Officer. The organization will respond within 30 calendar days.

5.4 Data Breach Notification Obligations

A data breach occurs when personal data is accessed, disclosed, altered, destroyed, or lost without authorization. Every employee has a duty to report suspected or confirmed data breaches immediately. The following response timeline applies:

Timeframe	Required Action
Within 1 hour of discovery	Employee reports the incident to their direct manager and IT helpdesk via the incident reporting portal or phone hotline
Within 4 hours	IT Security team assesses the scope and nature of the breach and initiates containment measures
Within 24 hours	Data Protection Officer (DPO) is notified and an initial internal incident report is completed
Within 72 hours	If the breach involves personal data and is likely to result in a risk to individuals, the relevant regulatory authority must be notified (as required by GDPR and local privacy laws)
Within 7 days	Affected individuals are notified if the breach is likely to result in a high risk to their rights and freedoms
Within 30 days	Full post-incident review and remediation plan completed

REAL-WORLD EXAMPLE

An employee at an e-commerce company accidentally emailed a spreadsheet containing 500 customer names, email addresses, and order histories to the wrong recipient. They noticed the error immediately but waited two days before reporting it. The delay resulted in the company being fined for non-compliance with data breach notification rules. Always report data incidents immediately — even if you are unsure whether it qualifies as a breach.

6. Internet and Network Usage Policy

6.1 Corporate Network Access

The organization provides internet access to employees as a business tool. This access is a privilege, not an unconditional right, and must be used primarily to fulfil work responsibilities. The organization's network infrastructure, bandwidth, and connected systems must be protected from misuse, excessive load, and security threats.

All internet traffic on the corporate network is subject to monitoring, logging, and analysis by the IT department for security and compliance purposes. Employees have no expectation of privacy when using company networks or company-provided internet access. By accepting this policy, employees acknowledge and consent to this monitoring.

6.2 Permitted Internet Activities

- Work-related research, information gathering, and professional development
- Access to job-relevant SaaS platforms, cloud applications, and business tools
- Professional networking (e.g., LinkedIn) when it serves a business purpose
- Accessing news and current events as related to business and industry
- Limited personal use during lunch breaks and non-work hours (see Section 6.3)

6.3 Prohibited Internet Activities

The following activities are strictly prohibited on company networks and company devices, regardless of whether the employee is in the office or working remotely:

Strictly Prohibited Online Activities
• Accessing pornographic, adult, or sexually explicit content of any kind
• Downloading or distributing pirated software, movies, music, or other copyrighted material
• Visiting websites associated with hacking tools, illegal services, or the dark web
• Participating in online gambling or gaming using company networks
• Streaming high-bandwidth entertainment (e.g., Netflix, YouTube for personal use) which consumes network resources
• Accessing social media platforms for extended personal use during working hours
• Using the internet to harass, bully, defame, or threaten any individual
• Engaging in cryptocurrency mining or trading using company infrastructure

- Transmitting malicious code, participating in distributed denial of service (DDoS) attacks, or any hacking activity

6.4 Remote Work and Personal Network Usage

Employees working remotely must take additional precautions to protect company data and systems:

- Always connect to company systems via the company-approved VPN when working remotely.
- Avoid using public Wi-Fi networks (cafes, airports, hotels) to access company systems. If unavoidable, always use the VPN.
- Personal home routers must have a strong Wi-Fi password (WPA3 or WPA2 at minimum) and must be updated regularly.
- Do not connect company devices to unsecured or unknown Wi-Fi hotspots.
- Family members or guests must not be allowed to use company devices, even if the employee is present.

6.5 Cloud Storage and File Sharing

The use of cloud storage services must comply with the following guidelines:

- Company-approved cloud storage (e.g., Google Drive, OneDrive, SharePoint) may be used for business data when properly configured with access controls.
- Personal cloud storage services (e.g., personal Dropbox, personal Google Drive, iCloud) must NOT be used to store, share, or transfer company data of any classification.
- File sharing via WeTransfer, public Dropbox links, or similar unauthenticated platforms is prohibited for confidential or restricted data.
- All company data shared externally must use a company-managed sharing link with appropriate expiration dates and access permissions.

7. Email and Communication Security

7.1 Professional Email Use Standards

Corporate email accounts are an official communication tool and represent the organization. All email communications must maintain a professional tone and comply with legal, ethical, and security standards.

- Employees must use only their company-issued email address for all business communications. Using personal email addresses for business correspondence is prohibited.
- Email should not be used to transmit Level 4 Restricted data unless it is encrypted end-to-end using IT-approved encryption tools.
- Bulk email communications (newsletters, announcements) must be sent through authorized email marketing platforms only.
- Auto-forwarding of corporate emails to personal email accounts is strictly prohibited.

7.2 Phishing and Social Engineering Awareness

Phishing attacks — fraudulent emails that attempt to trick employees into revealing credentials, clicking malicious links, or downloading malware — are among the most common and effective attack vectors against organizations. Every employee must know how to recognize and respond to phishing attempts.

Warning Signs of a Phishing Email:

- Urgent or threatening language demanding immediate action
- Requests for passwords, credit card numbers, or sensitive information
- Misspelled domain names (e.g., 'support@comp4ny.com' instead of 'company.com')
- Generic greetings ('Dear User') rather than your name
- Unexpected attachments, especially .exe, .zip, .docm files
- Links that don't match the displayed text (hover to preview the URL)
- Requests from executives for urgent wire transfers or gift card purchases

REAL-WORLD EXAMPLE

A finance employee received an email appearing to be from the CFO asking for an urgent bank transfer of \$42,000 to a new vendor account. The email domain was 'companycorp.com' instead of 'company.com' — a one-character difference. Not noticing this, the employee processed the transfer. The money was unrecoverable. This type of attack, called Business Email Compromise (BEC), costs organizations billions globally each year. When in doubt, always verify financial requests by phone.

Required Actions When You Receive a Suspicious Email:

14. Do NOT click any links or open attachments
15. Do NOT reply to the email
16. Forward the email as an attachment to security@company.com
17. Delete the email from your inbox
18. If you accidentally clicked a link or opened an attachment, immediately disconnect from the network and call IT Security

8. Artificial Intelligence (AI) Tool Usage Policy

8.1 Introduction and Context

The rapid proliferation of Artificial Intelligence tools — including large language models (LLMs), generative AI platforms, AI-powered code assistants, and automated content generators — presents both significant opportunities and substantial risks for organizations. Employees increasingly use tools such as ChatGPT, Microsoft Copilot, Google Gemini, Claude, Jasper, GitHub Copilot, and others in their daily work.

While the organization recognizes the productivity and innovation value of AI tools, their use without proper governance creates serious risks to data confidentiality, intellectual property, regulatory compliance, and output quality. This section establishes the organization's comprehensive AI usage policy to enable employees to benefit from AI while managing these risks responsibly.

8.2 Approved AI Tools

Employees may only use AI tools that have been reviewed and approved by the IT and Legal departments. The following categories of AI use are addressed:

Category	Guidance
Microsoft Copilot (M365)	Approved for use within the Microsoft 365 ecosystem. Data remains within the organization's M365 tenant under existing data governance controls.
GitHub Copilot	Approved for developers on the engineering team. Code suggestions may be used but must be reviewed before deployment. Organization code must not be uploaded to public repositories.
ChatGPT (OpenAI) — Free/Plus	NOT approved for handling any data classified Level 2 or above. May only be used for general knowledge queries that do not contain company information.
ChatGPT Enterprise / OpenAI API	Under evaluation. Currently not approved. Watch for IT announcements.
Google Gemini (personal account)	NOT approved for company data. Gemini via Google Workspace may be approved depending on organizational plan — check with IT.
Claude (Anthropic)	NOT approved for handling confidential data on consumer tier. Enterprise tier under evaluation.
Custom/Internal AI Tools	Subject to individual approval by IT and Legal. Must undergo security review before deployment.

8.3 What You Must NEVER Input into AI Tools

Regardless of which AI tool you are using, the following types of information must NEVER be entered into any AI platform, chatbot, or generative tool unless it is a fully approved enterprise solution with contractual data protections:

PROHIBITED INPUTS — Never Enter Into AI Tools	
	• Full names, addresses, contact details, or any personally identifiable information (PII) of employees, clients, or partners
	• Employee salary, compensation, or performance data
	• Client names, contract terms, pricing, or any client-specific business information
	• Proprietary algorithms, trade secrets, source code, or product roadmaps
	• Financial data including revenue figures, budgets, investment plans, or M&A information
	• Legal documents, NDAs, contracts, or any legally privileged communication
	• Internal strategic plans, board meeting notes, or executive communications
	• Passwords, API keys, authentication tokens, or any access credentials
	• HR case details, disciplinary information, or employee relations data

REAL-WORLD EXAMPLE	<i>A marketing employee was preparing a pitch deck and used ChatGPT (personal account) to help draft content. To make the output relevant, they pasted the client's company name, a summary of confidential contract terms, and the proposed campaign budget into the prompt. This data was processed by OpenAI's servers outside the organization's control. The client, upon learning this, terminated the contract citing confidentiality breach. Always anonymize or remove sensitive details before using any AI tool.</i>
--------------------	--

8.4 AI Output Validation and Quality Control

AI-generated content is not infallible. Employees must apply critical judgment to all AI outputs:

- AI tools can 'hallucinate' — generating plausible-sounding but factually incorrect information. Never use AI output in client-facing documents, legal filings, financial reports, or compliance submissions without thorough verification.
- AI tools may produce biased outputs based on their training data. Critically review AI-generated content for bias, stereotypes, or inappropriate framing.
- Code generated by AI assistants must be reviewed by a qualified developer before deployment. AI-generated code may contain security vulnerabilities, deprecated functions, or license-incompatible segments.

- Content generated by AI must be clearly identified as AI-assisted when submitted for review, publication, or client delivery — unless the output has been thoroughly reviewed, edited, and validated by the employee.

8.5 Intellectual Property and AI

Using AI tools raises complex intellectual property questions that employees must be aware of:

- Content created using AI tools that was trained on third-party data may have unclear copyright status. Consult Legal before using AI-generated content in client deliverables or published materials.
- Feeding proprietary organizational content (documents, code, creative work) into AI tools may transfer rights or expose confidential IP depending on the tool's terms of service.
- Employees must not claim AI-generated work as entirely their own creation when submitting deliverables where originality is expected — appropriate disclosure is required.

8.6 AI Usage Monitoring and Compliance

The organization will periodically audit the use of AI tools to ensure compliance with this policy. Employees found to have inputted restricted data into unauthorized AI platforms will be subject to disciplinary action in accordance with the organization's Disciplinary Policy. Repeated violations or violations involving highly sensitive data may result in immediate suspension of IT access rights pending investigation.

9. Security Incident Response

9.1 What Constitutes a Security Incident

A security incident is any event that actually or potentially compromises the confidentiality, integrity, or availability of information or systems. Employees must be aware of the broad range of events that qualify as security incidents:

Incident Category	Examples	Initial Severity
Device Loss/Theft	Lost laptop, stolen phone, missing USB drive containing company data	High
Unauthorized Access	Unknown person accessing your workstation, account access from unrecognized location	High
Malware/Ransomware	Computer running unusually slow, strange pop-ups, files encrypted, ransom demands	Critical
Phishing/Social Engineering	Clicking a suspicious link, responding to a phishing email, being tricked into revealing credentials	Medium-High
Data Exposure	Accidentally emailing data to wrong recipient, misconfigured cloud storage, data sent to wrong client	Medium-High
Policy Violation	Employee found storing company data on personal cloud, using unauthorized tools	Low-Medium
Vendor/Third-Party Incident	Notification from a supplier that their systems were breached and they held your company data	High

9.2 Incident Reporting Process

Every employee is obligated to report any suspected or confirmed security incident immediately. The reporting process is as follows:

19. Step 1 — Do Not Panic or Attempt to Fix It Yourself: Stop what you are doing. Do not attempt to investigate, fix, delete, or cover up the incident. Tampering with evidence of a breach may make the situation significantly worse.
20. Step 2 — Isolate the Affected System (if applicable): If you suspect malware or active intrusion, disconnect the affected device from the network by unplugging the Ethernet cable or disabling Wi-Fi. Do NOT turn the device off.

21. Step 3 — Report Immediately: Contact the IT Security Helpdesk via the emergency hotline (ext. 9911 or security@company.com). Provide your name, the nature of the incident, when you noticed it, and which systems are affected.
22. Step 4 — Document the Details: While they are fresh in your memory, write down everything you observed — error messages, unusual activity, emails received, actions you took. This documentation is invaluable for the investigation.
23. Step 5 — Do Not Discuss the Incident: Do not discuss the incident on email, messaging apps, or social media. Security incidents are confidential matters and must only be discussed with IT Security and authorized personnel.

9.3 Non-Retaliation for Good-Faith Reporting

The organization strictly prohibits any form of retaliation against employees who report security incidents in good faith. An employee who accidentally causes a security incident and reports it promptly and honestly will be treated very differently from an employee who conceals an incident. Concealment will be treated as a serious disciplinary offence; good-faith reporting will be treated as responsible behaviour and will be factored into any consequences.

10. Bring Your Own Device (BYOD) Policy

10.1 BYOD Scope and Eligibility

Employees in designated roles may use their personally owned devices (smartphones, tablets, and in limited cases, laptops) to access certain company systems and applications. BYOD is a privilege extended to improve flexibility and productivity, not a right. The use of personal devices to access company systems is subject to the conditions in this section.

10.2 BYOD Security Requirements

Before a personal device is used to access any company system, the following requirements must be met and maintained:

- The device must be registered with the IT department through the Mobile Device Management (MDM) portal.
- The device must have a strong passcode/biometric lock enabled and must auto-lock after 2 minutes of inactivity.
- The device's operating system must be on the latest supported version with all security patches applied.
- The company's Mobile Device Management (MDM) profile must be installed, which allows remote wipe of company data in case of loss or theft.
- Jailbroken or rooted devices are strictly prohibited from accessing company systems.
- Employees must immediately report to IT if their personal device used for company access is lost, stolen, or compromised.

10.3 Company Rights on BYOD Devices

By enrolling a personal device in BYOD, employees acknowledge that:

- The organization may remotely wipe company data from the device if it is lost, stolen, or if the employee leaves the organization. This wipe is targeted to company data containers only and should not affect personal data.
- The organization may monitor network traffic originating from the device when connected to company resources.
- The company's MDM solution may collect device metadata including device type, OS version, and compliance status.

11. Social Media and Online Conduct Policy

11.1 Professional Representation

Employees who identify themselves as company employees on public social media platforms are representing the organization, whether intentionally or not. The following guidelines apply to all social media activity by employees, whether on company time or personal time:

- Do not share confidential company information, client details, or internal business matters on any social media platform.
- Do not post negative, derogatory, or defamatory content about the organization, its leadership, clients, or competitors.
- Exercise good judgment before posting anything that could reflect poorly on the organization.
- If you are unsure whether something can be shared, assume it cannot and consult the Communications team.
- Clearly distinguish personal opinions from the organization's official positions when posting about topics related to your industry.

REAL- WORLD EXAMPLE

An employee posted a LinkedIn status update saying: 'Just closed our biggest deal ever — \$5M with [Client Name]!' while tagging the client. The client had a strict confidentiality clause and was furious about the public disclosure of contract details. The organization faced a formal complaint and nearly lost the client relationship. Never share deal sizes, client names, or business outcomes publicly without explicit authorization.

12. Third-Party Vendor and Supplier Security

12.1 Vendor Risk Assessment

Third-party vendors who process, store, or have access to organizational data represent a significant and often underestimated security risk. The organization's security is only as strong as its weakest link — and that link is often a vendor with weaker security controls.

Before engaging any vendor who will have access to Level 3 or Level 4 data, the procurement and IT teams must conduct a Vendor Security Assessment covering:

- Data handling and protection practices
- Security certifications (ISO 27001, SOC 2, etc.)
- Incident response capabilities and breach notification procedures
- Data residency and subprocessor arrangements
- Access control and authentication methods
- Business continuity and disaster recovery plans

12.2 Contractual Security Requirements

All vendor contracts involving access to organizational data must include:

- A Data Processing Agreement (DPA) compliant with applicable privacy laws
- Clear specification of data types, processing purposes, and retention periods
- Security obligations and standards the vendor must maintain
- Breach notification obligations (typically within 24-72 hours of discovery)
- Right to audit clauses allowing the organization to verify vendor compliance
- Data deletion/return obligations upon contract termination

13. Policy Enforcement and Consequences

13.1 Compliance Monitoring

The IT department, in coordination with HR and Compliance, will monitor adherence to this policy through the following mechanisms:

- Regular automated security scans of all company devices
- Network traffic analysis and anomaly detection
- Periodic review of access logs and privilege usage
- Annual security audits by internal and/or external auditors
- Phishing simulation exercises (employees who fail repeated simulations receive mandatory training)
- Random spot checks of device compliance and software configurations

13.2 Consequences of Policy Violations

Violations of this policy will be handled in accordance with the organization's Disciplinary Policy. The severity of consequences will be commensurate with the nature, frequency, intent, and impact of the violation:

Violation Severity	Examples	Potential Consequences
Minor	Brief personal internet use exceeding guidelines, failure to lock screen promptly	Verbal warning, mandatory refresher training
Moderate	Installing unauthorized software, using personal email for company data, sharing a password	Written warning, temporary access restrictions, mandatory security training
Serious	Storing restricted data on personal/unauthorized cloud, repeated policy violations, ignoring security patches for extended periods	Final written warning, suspension of IT privileges, formal disciplinary hearing
Severe / Gross Misconduct	Deliberate data theft, sharing trade secrets with competitors, intentionally bypassing security controls, unauthorized AI input of restricted data	Immediate suspension pending investigation, termination, civil or criminal legal action

13.3 Whistleblower Protection

Employees who report suspected security policy violations in good faith are protected from retaliation. Reports can be made anonymously through the organization's whistleblower hotline or ethics portal. All reports will be treated confidentially and investigated promptly.

14. Security Awareness Training

14.1 Mandatory Training Requirements

Security awareness training is mandatory for all employees. The following training requirements apply:

Training Requirement	Details
Onboarding Security Training	All new employees must complete the organization's Security Awareness Induction module within their first 5 working days. Includes data classification, password policy, phishing recognition, and acceptable use training.
Annual Refresher Training	All employees must complete an annual security refresher course, typically released in Q1. Non-completion by the deadline results in an automatic escalation to the employee's line manager.
Phishing Simulation Programme	The IT department conducts quarterly simulated phishing campaigns. Employees who fail simulations receive immediate targeted training and their manager is notified.
Role-Specific Training	Employees in Finance, HR, IT, Legal, and Executive roles must complete additional training tailored to the specific risks associated with their data access and job functions.
Incident-Triggered Training	Any employee involved in a security incident may be required to undergo targeted remedial training as determined by IT Security and HR.

15. Policy Review, Acknowledgement, and Updates

15.1 Policy Review Cycle

This policy will be reviewed annually by the IT Security team, HR department, and Legal/Compliance team. Ad-hoc reviews may be triggered by significant changes in technology, regulatory requirements, security incidents, or organizational structure. The version history below documents all significant changes:

Version	Date	Summary of Changes
1.0	January 1, 2025	Initial policy release. Covers all sections including new AI Tool Usage Policy.
Next Review	January 1, 2026	Scheduled annual review. AI tool landscape, regulatory updates, and incident learnings to be incorporated.

15.2 Employee Acknowledgement

All employees must read, understand, and formally acknowledge this policy. Acknowledgement is completed through the HR Information System (HRIS) and constitutes a binding agreement to comply with all policy terms. Failure to acknowledge within 10 business days of receipt will be escalated to the employee's line manager.

Employee Name:	
Department:	
Signature:	
Date of Acknowledgement:	

— End of Data Security Policy —

For queries, contact: itsecurity@company.com | HR Department: hr@company.com